

CVEs más relevantes de la semana

Del 28/04/2026 al 05/05/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-41386

Descripción: OpenClaw before 2026.3.22 contains a privilege escalation vulnerability where bootstrap setup codes are not bound to intended device roles and scopes during pairing. Attackers can exploit this during first-use device pairing to escalate privileges beyond their intended role and scope.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-648

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-41397

Descripción: OpenClaw before 2026.3.31 contains a sandbox escape vulnerability allowing attackers to traverse directory boundaries through symlink exploitation during file synchronization operations. Remote attackers can bypass sandbox restrictions by crafting malicious symlinks in mirror sync operations to access arbitrary files outside intended boundaries.

CVSS: 6.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-41446

Descripción: Snap One WattBox 800 and 820 series firmware versions prior to 2.10.0.0 contain undisclosed diagnostic HTTP endpoints that require only the device MAC address and service tag for authentication, both of which are printed in plaintext on the physical device label. Attackers with access to the device label or documentation containing these values can authenticate to the several endpoints and exec...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-26015

Descripción: DocsGPT is a GPT-powered chat for documentation. From version 0.15.0 to before version 0.16.0, an attacker accessing both the official DocsGPT website or any local and public deployment, can craft a malicious payload bypassing the "MCP test" behavior to achieve arbitrary remote code execution (RCE). This issue has been patched in version 0.16.0.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2026-30893

Descripción: Wazuh is a free and open source platform used for threat prevention, detection, and response. From version 4.4.0 to before version 4.14.4, a path traversal vulnerability in Wazuh's cluster synchronization extraction routine allows an authenticated cluster peer to write arbitrary files outside the intended extraction directory on other cluster nodes. This can be escalated to code execution in th...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:L/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2018-25316

Descripción: Tenda W308R v2 V5.07.48 contains a cookie session weakness vulnerability that allows unauthenticated attackers to modify DNS settings by exploiting insufficient session validation. Attackers can send GET requests to the goform/AdvSetDns endpoint with a crafted admin language cookie to change DNS servers and redirect user traffic to malicious sites.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2018-25317

Descripción: Tenda W3002R/A302/W309R wireless routers version V5.07.64_en contain a cookie session weakness vulnerability that allows unauthenticated attackers to modify DNS settings by exploiting insufficient session validation. Attackers can send GET requests to the /goform/AdvSetDns endpoint with a crafted admin language cookie to change primary and secondary DNS servers, redirecting user traffic to mali...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2018-25318

Descripción: Tenda FH303/A300 firmware V5.07.68_EN contains a session weakness vulnerability that allows unauthenticated attackers to modify DNS settings by exploiting insufficient cookie validation. Attackers can send GET requests to the /goform/AdvSetDns endpoint with a crafted admin cookie to change DNS servers and redirect user traffic to malicious sites.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2025-13030

Descripción: All versions of the package django-mdeditor are vulnerable to Missing Authentication for Critical Function in the image upload endpoint. An attacker can upload malicious files and achieve arbitrary code execution since this endpoint lacks authentication protection and proper sanitisation of file names.

CVSS: 7.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:L

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-22070

Descripción: ColorOS Assistant has an unauthenticated start-download channel, leading to file path traversal.

CVSS: 7.1 (HIGH)

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:C/C:N/I:L/A:H

Tipo: CWE-23

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-42799

Descripción: Out-of-bounds read vulnerability in ASR Kestrel (nr_fw modules) allows Overflow Buffers.

This vulnerability is associated with program files
Code/Nr/nr_fw/RA/src/NrPwrCtrl.C.

This issue affects Kestrel: before 2026/02/10.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:L

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2025-14543

Descripción: Improper Restriction of XML External Entity Reference vulnerability in Connexxt Professional (Core Libraries) allows Serialized Data External Linking. This issue affects Connexxt Professional: from 7.4.0 before 7.7.0, from 7.0.0 before 7.3.1.1, from 6.1.0 before 6.1.*, from 6.0.0 before 6.0.*, from 5.3.0 before 5.3.*, from 4.3x before 5.2.*.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-611

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2022-50993

Descripción: Weaver (Fanwei) E-office versions prior to 10.0_20221201 contain an unauthenticated arbitrary file upload vulnerability in the OfficeServer.php endpoint that allows remote attackers to upload malicious files by sending multipart POST requests with arbitrary filenames and disguised content types. Attackers can upload PHP webshells to the Document directory and execute them via HTTP GET requests ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2025-71284

Descripción: Synway SMG Gateway Management Software contains an OS command injection vulnerability in the RADIUS configuration endpoint at /en/9-2radius.php where the radius_address POST parameter is split and interpolated directly into a sed command without sanitization. An unauthenticated remote attacker can inject arbitrary shell commands by submitting a POST request with crafted radius_address, radius_a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-33845

Descripción: A flaw in GnuTLS DTLS handshake parsing allows malformed fragments with zero length and non-zero offset, leading to an integer underflow during reassembly and resulting in an out-of-bounds read. This issue is remotely exploitable and may cause information disclosure or denial of service.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Tipo: CWE-191

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-33446

Descripción: CVE-2026-33446 is a buffer overflow in the authentication sub-system of the Secure Access client prior to 14.50. Attackers with control of a modified server can send a special packet that can overwrite a small portion of memory conceivably leading to memory corruption or a denial of service.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-33447

Descripción: CVE-2026-33447 is a buffer overflow in a message parsing function of the Secure Access client prior to 14.50.

Attackers with control of a modified server can send a special packet that can overwrite a small portion of memory conceivably leading to memory corruption or denial of service.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-35051

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to versions 2.11.43, 3.6.14, and 3.7.0-rc.2, there is an authentication bypass vulnerability in Traefik's ForwardAuth middleware when trustForwardHeader=false is configured and Traefik is deployed behind a trusted upstream proxy. This issue has been patched in versions 2.11.43, 3.6.14, and 3.7.0-rc.2.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-39858

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to versions 2.11.43, 3.6.14, and 3.7.0-rc.2, there is a high severity authentication bypass vulnerability in Traefik's ForwardAuth and snippet-based authentication middleware. Traefik's forwarded-header sanitization logic targets only canonical header names (e.g., X-Forwarded-Proto) and does not strip or normalize alias variants that use...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-2311

Descripción: IBM i 7.6, 7.5, 7.4, 7.3, and 7.2 s vulnerable to privilege escalation caused by an invalid IBM i Web Administration GUI authorization check. A malicious actor could cause user-controlled code to run with administrator privilege.

CVSS: 6.4 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-40685

Descripción: In Exim before 4.99.2, when JSON lookup is enabled, an out-of-bounds heap write can occur when a JSON operator encounters malformed JSON in an untrusted header, because of an incorrect implementation of \ skipping.

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:H

Tipo: CWE-684

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-40687

Descripción: In Exim before 4.99.2, when the SPA authentication driver is used with an adversarial SPA resource, there can be an out-of-bounds write that crashes the connection instance, or erroneous data processing that divulges data from uninitialized heap memory.

CVSS: 4.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:L

Tipo: CWE-909

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-7538

Descripción: A vulnerability was identified in Totolink A8000RU 7.1cu.643_b20200521. This issue affects the function Vulnerability of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument proto leads to os command injection. The attack may be initiated remotely. The exploit is publicly available and might be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-7546

Descripción: A security vulnerability has been detected in Totolink NR1800X 9.1.0u.6279_B20210910. The impacted element is the function find_host_ip of the component lighttpd. Such manipulation of the argument Host leads to stack-based buffer overflow. The attack can be executed remotely. The exploit has been disclosed publicly and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-42994

Descripción: Bitwarden CLI 2026.4.0 from 2026-04-22T21:57Z to 2026-04-22T23:30Z, when obtained from npm, had embedded malicious code. This is related to a Checkmarx supply chain incident.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-7567

Descripción: The Temporary Login plugin for WordPress is vulnerable to Authentication Bypass in versions up to and including 1.0.0. This is due to improper input validation in the `maybe_login_temporary_user()` function, which fails to verify that the 'temp-login-token' GET parameter is a scalar string before processing it. When the parameter is supplied as an array, PHP's `empty()` check is bypassed and sanit...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-42482

Descripción: A stack-based buffer overflow in `mangle_to_hex_lower()` and `mangle_to_hex_upper()` in `src/rp_cpu.c` in `hashcat v7.1.2` allows an attacker to cause a denial of service or possibly execute arbitrary code via a crafted rule file, or via the `-j` or `-k` rule options used with password candidates of 128 or more characters. The vulnerability is caused by a bounds check that fails to account for the 2x expansion of the rule file.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-42483

Descripción: A heap-based buffer overflow in the Kerberos hash parser in hashcat v7.1.2 allows an attacker to cause a denial of service or possibly execute arbitrary code via a crafted Kerberos hash file. The issue affects module_hash_decode in multiple Kerberos-related modules because account_info_len is calculated from untrusted delimiter positions without upper-bound validation before memcpy copies the d...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-42484

Descripción: A heap-based buffer overflow in hex_to_binary in the PKZIP hash parser in hashcat v7.1.2 allows an attacker to cause a denial of service or possibly execute arbitrary code via a crafted PKZIP hash file. The issue affects modules 17200, 17210, 17220, 17225, and 17230. When data_type_enum<=1, attacker-controlled hex data from a user-supplied hash string is decoded into a fixed-size buffer without...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-4882

Descripción: The User Registration Advanced Fields plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the 'URAF_AJAX::method_upload' function in all versions up to, and including, 1.6.20. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution possible. Note: The vulnera...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-02



CVE-2026-7458

Descripción: The User Verification by PickPlugins plugin for WordPress is vulnerable to authentication bypass in all versions up to, and including, 2.0.46. This is due to the use of a loose PHP comparison operator to validate OTP codes in the "user_verification_form_wrap_process_otpLogin" function. This makes it possible for unauthenticated attackers to log in as any user with a verified email address, such...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-05-02



CVE-2026-42370

Descripción: A stack overflow vulnerability exists in the WebCam Server Login functionality of GeoVision GV-VMS V20 20.0.2. A specially crafted HTTP request can lead to an arbitrary code execution. An attacker can make an unauthenticated HTTP request to trigger this vulnerability.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-04



CVE-2026-7372

Descripción: A stack overflow vulnerability exists in the WebCam Server Login functionality of GeoVision GV-VMS V20 20.0.2. A specially crafted HTTP request can lead to an arbitrary code execution. An attacker can make an unauthenticated HTTP request to trigger this vulnerability.

Stack-overflow via unconstrained sscanf

The call to `sscanf` at [1] to split the `Buffer` variable into the `username` an...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-04



CVE-2026-7719

Descripción: A security flaw has been discovered in Totolink WA300 5.2cu.7112_B20190227. The affected element is the function loginauth of the file /cgi-bin/cstecgi.cgi of the component POST Request Handler. The manipulation of the argument http_host results in buffer overflow. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-05-04



CVE-2025-14320

Descripción: Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Tegsoft Management and Information Services Trade Limited Company Online Support Application allows Reflected XSS.

This issue affects Online Support Application: from V3 through 31122025.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-05-04



CVE-2026-7747

Descripción: A security flaw has been discovered in Totolink N300RH 3.2.4-B20220812. Affected by this vulnerability is the function loginauth of the file /cgi-bin/cstecgi.cgi of the component Parameter Handler. Performing a manipulation of the argument Password results in buffer overflow. The attack can be initiated remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-05-04



CVE-2026-25293

Descripción: Buffer overflow due to incorrect authorization in PLC FW

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-05-04



CVE-2026-42796

Descripción: Arelle before 2.39.10 contains an unauthenticated remote code execution vulnerability in the /rest/configure REST endpoint that accepts a plugins query parameter and forwards it to the plugin manager without authentication or authorization.

Attackers can supply a URL to a malicious Python file through the plugins parameter, causing the Arelle webserver to download and execute the attacker-contr...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-04



CVE-2026-5722

Descripción: The MoreConvert Pro plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 1.9.14. This is due to the guest waitlist verification flow not invalidating or regenerating verification tokens when the customer email address is changed. This makes it possible for unauthenticated attackers to authenticate as existing users, including administrators, by obtai...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2025-13618

Descripción: The Mentoring plugin for WordPress is vulnerable to privilege escalation in all versions up to, and including, 1.2.8.

This is due to the plugin not properly restricting the roles that users can register with in the mentoring_process_registration() function. This makes it possible for unauthenticated attackers to register with administrator-level user accounts.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2026-5294

Descripción: The Geeky Bot plugin for WordPress is vulnerable to Missing Authorization in versions up to, and including, 1.2.2.

This is due to a nopriv AJAX route allowing attacker-controlled model/function dispatch and reaching a plugin installer helper that downloads and unzips attacker-supplied ZIP files into wp-content/plugins/. This makes it possible for unauthenticated attackers to perform arbitrary p...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2026-7823

Descripción: A security flaw has been discovered in Totolink A8000RU 7.1cu.643_b20200521. Affected is the function setAppFilterCfg of the file /cgi-bin/cstecgi.cgi. The manipulation of the argument enable results in os command injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2023-54342

Descripción: Eclipse Equinox OSGi versions 3.8 through 3.18 contain a remote code execution vulnerability in the console interface that allows unauthenticated attackers to execute arbitrary code by exploiting the fork command functionality. Attackers can establish a telnet connection to the OSGi console, perform a telnet handshake, and send fork commands to download and execute malicious Java code, establis...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2023-54344

Descripción: Eclipse Equinox OSGi 3.7.2 and earlier contains a remote code execution vulnerability that allows unauthenticated attackers to execute arbitrary commands by sending payloads to the console interface. Attackers can connect to the OSGi console port and send base64-encoded bash commands wrapped in fork directives to achieve code execution and establish reverse shell connections.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2026-43534

Descripción: OpenClaw before 2026.4.10 contains an input validation vulnerability that allows external hook metadata to be enqueued as trusted system events. Attackers can supply malicious hook names to escalate untrusted input into higher-trust agent context.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2026-43566

Descripción: OpenClaw versions 2026.4.7 before 2026.4.14 contain a privilege escalation vulnerability where heartbeat owner downgrade logic skips webhook wake events carrying untrusted content.

Attackers can exploit this by sending untrusted webhook wake events to preserve owner-like execution context when the run should have been downgraded.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-184

Tecnología: No especificado

Publicado el: 2026-05-05



CVE-2026-7834

Descripción: A security vulnerability has been detected in EFM ipTIME NAS1dual 1.5.24. This issue affects the function `get_csrf_whites` of the file `/cgi/advanced/misc_main.cgi`. Such manipulation leads to stack-based buffer overflow. The attack can be launched remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-05-05



Resumen del Reporte

CVEs analizados: 47

Promedio CVSS: 9.17

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☺

